

Part A — MFA Setup

4.1 SMS OTP Setup

4.1.1 Overview

SMS-based One-Time Password (OTP) authentication is implemented at FinSecure Pvt. Ltd. as a **fallback authentication method**. While it provides an additional layer of security over password-only authentication, it is not used as a primary MFA method due to known vulnerabilities such as SIM swapping and interception.

4.1.2 Configuration Steps

4.1.2.1. Enable SMS Authentication in Identity Provider

- Navigate to the MFA settings in the identity provider (e.g., Microsoft Entra ID / Azure AD)
 - Enable **SMS-based OTP authentication**
 - Configure it as a **secondary or backup method only**
-

4.1.2.2. Configure User Phone Numbers

- Ensure all users have valid mobile numbers registered
 - Enforce number verification during enrollment
 - Store numbers securely in the directory
-

4.1.2.3. Define Authentication Policies

- Restrict SMS OTP usage to:
 - Account recovery
 - Backup authentication
 - Disable SMS as primary MFA method
-

4.1.2.4. Configure OTP Parameters

- OTP validity: 30–60 seconds
- Maximum retry attempts: 3–5

- Lockout after repeated failures
-

4.1.2.5. Integrate with Login Flow

- Enable SMS OTP as fallback when:
 - Authenticator app is unavailable
 - Device is not accessible
-

4.1.3 Testing & Validation

- Verify OTP delivery to registered numbers
 - Test login using SMS fallback scenario
 - Simulate failure cases (expired OTP, incorrect OTP)
 - Confirm account lockout after multiple failed attempts
-

4.1.4 Security Considerations

- Vulnerable to SIM swapping and phishing
 - Susceptible to interception in insecure networks
 - Should not be used for high-risk accounts (admins, finance)
-

4.1.5 Recommended Usage at FinSecure

- Use only as a **backup authentication method**
 - Avoid for:
 - Privileged users
 - Critical system access
-

4.1.6 Summary

SMS OTP provides a basic second factor for authentication and serves as a fallback mechanism within FinSecure's MFA framework. However, due to its inherent security limitations, its usage is restricted and supplemented with stronger authentication methods.

4.2 Email OTP Setup

4.2.1 Overview

Email-based One-Time Password (OTP) authentication is implemented at FinSecure Pvt. Ltd. as a **secondary fallback mechanism** for MFA. It is primarily used in scenarios where the primary authentication method (e.g., authenticator app) is unavailable.

While email OTP adds a layer of security beyond passwords, it is dependent on the security of the user's email account and is therefore not considered a high-assurance authentication factor.

4.2.2 Configuration Steps

4.2.2.1. Enable Email OTP in Identity Provider

- Access MFA settings in the identity platform (e.g., Microsoft Entra ID / Azure AD)
 - Enable **Email-based OTP authentication**
 - Configure it strictly as a **backup authentication method**
-

4.2.2.2. Verify User Email Addresses

- Ensure all users have:
 - Registered corporate email IDs (Microsoft 365)
 - Verified email ownership
 - Enforce email validation during onboarding
-

4.2.2.3. Configure Authentication Policies

- Restrict usage of email OTP to:
 - Account recovery scenarios
 - Secondary fallback authentication
- Disable as a primary MFA method

4.2.2.4. Configure OTP Parameters

- OTP validity: 60–120 seconds
- Maximum retry attempts: 3–5
- Temporary lockout after multiple failures

4.2.2.5. Integrate with Authentication Flow

- Enable email OTP as fallback when:
 - Authenticator device is unavailable
 - User cannot access primary MFA method

4.2.3 Testing & Validation

- Verify OTP delivery to user email inbox
- Test login flow using email OTP fallback
- Simulate:
 - Expired OTP
 - Incorrect OTP entries
- Confirm lockout behavior after repeated failures

4.2.4 Security Considerations

- Security depends on email account protection
- If email is compromised, OTP can be intercepted
- Susceptible to phishing attacks

4.2.5 Recommended Usage at FinSecure

- Use only as a **backup authentication method**
 - Avoid for:
 - Admin accounts
 - Financial systems access
 - Ensure strong security controls on email accounts (MFA enforced on Microsoft 365)
-

4.2.6 Summary

Email OTP serves as a convenient fallback authentication method within FinSecure's MFA framework. However, due to its reliance on email security, it is restricted to low-risk scenarios and is not used as a primary authentication factor.

4.3 Authenticator App Setup

4.3.1 Overview

Authenticator app-based authentication is the **primary MFA method** implemented at FinSecure Pvt. Ltd. It provides a secure and reliable second factor using Time-Based One-Time Passwords (TOTP) or push-based verification.

This method is resistant to common attacks such as phishing (to an extent), credential stuffing, and SIM swapping, making it the preferred authentication mechanism for most users within the organization.

Supported applications include:

- Microsoft Authenticator
 - Google Authenticator
-

4.3.2 Configuration Steps

4.3.2.1. Enable Authenticator App in Identity Provider

- Navigate to MFA settings in the identity provider (e.g., Microsoft Entra ID / Azure AD)
 - Enable:
 - **Authenticator app (TOTP)**
 - Optional: **Push notifications**
 - Set as the **primary authentication method**
-

4.3.2.2. Configure User Enrollment Policy

- Require users to register an authenticator app during first login
- Enforce mandatory enrollment for:
 - All employees
 - Privileged users

4.3.2.3. User Registration Process

1. User logs into the system
2. MFA setup prompt is triggered
3. User scans QR code using authenticator app
4. App generates OTP or enables push notification
5. User verifies setup using generated code

4.3.2.4. Configure Authentication Settings

- OTP validity: 30 seconds (standard TOTP)
- Enable push notification approvals (optional but recommended)
- Limit number of failed attempts
- Enable device recognition (optional for usability)

4.3.2.5. Backup & Recovery Configuration

- Allow backup methods:
 - SMS OTP
 - Email OTP
- Provide recovery options:
 - IT-assisted reset
 - Temporary bypass (with approval)

4.3.3. Testing & Validation

- Test TOTP-based login across:
 - Microsoft 365
 - VPN
 - Internal applications
 - Validate:
 - QR code enrollment
 - OTP generation accuracy
 - Push notification approval
 - Simulate:
 - Device loss scenario
 - Incorrect OTP attempts
 - Recovery process
-

4.3.4. Security Considerations

- Stronger than SMS/email OTP
 - Still vulnerable to:
 - Phishing (if users approve malicious prompts)
 - MFA fatigue attacks (push spam)
-

4.3.5. Risk Mitigation Measures

- Enable number matching (for push notifications)
 - Limit repeated push requests
 - Educate users to avoid blind approvals
 - Monitor suspicious MFA activity
-

4.3.6. Recommended Usage at FinSecure

- **Primary MFA method for all employees**
 - Mandatory for:
 - Admin accounts
 - VPN access
 - Microsoft 365
-

4.3.7. Summary

Authenticator apps form the backbone of FinSecure's MFA implementation, offering a secure, scalable, and user-friendly authentication method. By combining TOTP and push-based verification, the organization achieves strong protection against credential-based attacks while maintaining usability.

4.4 Biometrics Setup

4.4.1. Overview

Biometric authentication is implemented at FinSecure Pvt. Ltd. as a **device-based authentication factor**, leveraging built-in hardware such as fingerprint sensors and facial recognition systems.

This method falls under “**something you are**” and is typically used in conjunction with trusted devices (e.g., laptops, smartphones). In enterprise environments, biometric authentication is commonly enabled through solutions such as **Windows Hello for Business**.

Biometrics provide a **high level of security and user convenience**, especially when combined with device binding and cryptographic protection.

4.4.2. Configuration Steps

4.4.2.1. Enable Biometric Authentication on Devices

- Ensure endpoint devices support:
 - Fingerprint recognition
 - Facial recognition (IR camera)
 - Enable biometric login via:
 - Windows Hello (for domain-joined systems)
 - Mobile device security settings
-

4.4.2.2. Configure via Identity Provider / Endpoint Policies

- Use Group Policy or Intune (for Microsoft environments) to:
 - Enable Windows Hello for Business
 - Enforce biometric login policies
 - Configure PIN + biometric combination for secure fallback
-

4.4.2.3. User Enrollment Process

1. User logs into device
 2. Navigates to biometric setup (e.g., Windows Hello)
 3. Registers fingerprint or facial data
 4. Sets up backup PIN
 5. Completes verification
-

4.4.2.4. Bind Biometrics to Device Identity

- Ensure biometric data is:
 - Stored locally on device (not centrally stored)
 - Protected using secure hardware (TPM)
- Link authentication to:

- Device identity
 - User credentials
-

4.4.2.5. Integrate with MFA Workflow

- Use biometrics as:
 - Primary login method on trusted devices
 - One factor in MFA flow (device + biometric)
 - Combine with:
 - Conditional access policies
 - Device compliance checks
-

4.4.3. Testing & Validation

- Verify biometric login on:
 - Domain-joined systems
 - Managed devices
 - Test scenarios:
 - Successful biometric authentication
 - Fallback to PIN
 - Device change or re-enrollment
-

4.4.4. Security Considerations

- Biometric data must never be stored centrally
 - Risk of spoofing (mitigated by modern sensors)
 - Requires secure hardware (TPM, secure enclave)
-

4.4.5. Risk Mitigation Measures

- Enforce liveness detection (anti-spoofing)
 - Use biometrics only on trusted, managed devices
 - Require fallback PIN/password
 - Combine with device compliance policies
-

4.4.6. Recommended Usage at FinSecure

- Enable for:
 - Corporate laptops and managed endpoints
 - Use as:
 - **Convenience + strong authentication factor**
 - Mandatory for:
 - Frequent-access users
 - Employees using company-issued devices
-

4.4.7. Summary

Biometric authentication enhances both security and user experience by enabling fast and secure access to systems. When combined with device binding and secure hardware, it serves as a strong authentication factor within FinSecure's MFA framework.

4.5 Hardware Token Setup (FIDO2 / Security Keys)

4.5.1. Overview

Hardware token-based authentication is implemented at FinSecure Pvt. Ltd. for **high-security use cases**, particularly for privileged and high-risk users.

These tokens (e.g., YubiKey, FIDO2 security keys) provide **phishing-resistant authentication** using public-key cryptography. Unlike OTP-based methods, they do not rely on shared secrets and are immune to interception or replay attacks.

This method represents the **highest level of authentication assurance** within the MFA framework.

4.5.2. Supported Devices

- FIDO2 Security Keys (e.g., YubiKey)
 - USB / NFC / Bluetooth-based hardware tokens
-

4.5.3. Configuration Steps

4.5.3.1. Enable FIDO2 Authentication in Identity Provider

- Navigate to MFA settings in the identity platform (e.g., Microsoft Entra ID)
 - Enable:
 - **FIDO2 Security Key authentication**
 - Configure policies for:
 - Allowed users/groups
 - Supported device types
-

4.5.3.2. Assign Tokens to Users

- Identify high-risk users:
 - IT administrators
 - Finance team
 - Senior management
 - Issue hardware tokens to selected users
 - Maintain inventory and asset tracking
-

4.5.3.3. User Registration Process

1. User logs into MFA setup portal
 2. Inserts or connects hardware token
 3. Registers the device
 4. Sets PIN (if required)
 5. Completes registration
-

4.5.3.4. Configure Authentication Policies

- Enforce hardware token usage for:
 - Privileged accounts
 - Critical systems access
 - Disable weaker MFA methods for these users where possible
-

4.5.3.5. Integrate with Login Flow

- During authentication:
 - User inserts token or taps device (NFC)
 - Confirms authentication (touch/press)
 - No OTP required
-

4.5.4. Testing & Validation

- Test login using hardware token across:
 - Microsoft 365
 - Admin portals
 - VPN (if supported)
 - Validate:
 - Device recognition
 - Successful authentication
 - PIN verification (if enabled)
-

4.5.5. Security Considerations

- Resistant to:
 - Phishing attacks
 - Man-in-the-middle attacks
 - Credential theft
 - Requires physical possession of device
-

4.5.6. Risk Mitigation Measures

- Issue backup token per critical user
 - Define lost/stolen token procedure
 - Enable rapid de-registration of compromised tokens
 - Maintain audit logs of token usage
-

4.5.7. Recommended Usage at FinSecure

- Mandatory for:
 - IT administrators
 - Privileged users
 - Optional for:
 - High-risk business roles (finance, leadership)
-

4.5.8. Summary

Hardware tokens provide the highest level of security within FinSecure's MFA implementation. By leveraging phishing-resistant authentication, they significantly reduce the risk of credential compromise and are essential for protecting critical systems and privileged accounts.

Part B — Integration

4.6 SSO Integration (SAML / OIDC)

4.6.1. Overview

Single Sign-On (SSO) integration enables users at FinSecure Pvt. Ltd. to access multiple enterprise applications using a single set of credentials, while enforcing Multi-Factor Authentication (MFA) through a centralized identity provider.

SSO is implemented using standard protocols such as:

- **SAML (Security Assertion Markup Language)** – commonly used for enterprise web applications
- **OIDC (OpenID Connect)** – modern authentication protocol used for cloud and API-based services

This integration ensures that MFA is applied consistently across all connected applications, improving both security and user experience.

4.6.2. Architecture Components

- **Identity Provider (IdP):**
 - Microsoft Entra ID (Azure AD)
 - **Service Providers (SPs):**
 - Microsoft 365
 - Internal web applications
 - Client-facing portal
 - **Users:**
 - Employees accessing systems via browser or VPN
-

4.6.3. Configuration Steps

4.6.3.1. Configure Identity Provider (IdP)

- Set up Microsoft Entra ID as the **central identity provider**
- Enable MFA enforcement at the IdP level
- Configure Conditional Access policies:
 - Require MFA for all users
 - Enforce stricter controls for high-risk logins

4.6.3.2. Integrate Applications with SSO

For SAML-based Applications

- Configure:
 - Assertion Consumer Service (ACS) URL
 - Entity ID
 - Exchange metadata between IdP and application
 - Map user attributes (e.g., email, username)
-

For OIDC-based Applications

- Register application in identity provider
 - Configure:
 - Client ID and Secret
 - Redirect URI
 - Enable authorization flow (Authorization Code Flow recommended)
-

4.6.3.3. Configure User Access Policies

- Assign users or groups to applications
 - Define access controls:
 - Role-based access
 - Least privilege principle
-

4.6.3.4. Enable MFA Enforcement via SSO

- Apply MFA policies at IdP level
 - Ensure:
 - MFA is triggered during login
 - High-risk scenarios trigger step-up authentication
-

4.6.4. Authentication Flow

1. User attempts to access application
2. User is redirected to Identity Provider
3. User enters credentials
4. MFA challenge is triggered
5. Upon successful authentication, token/assertion is securely issued
6. User gains access to application



Figure 4: SSO authentication flow with MFA enforcement.

4.6.5. Testing & Validation

- Test login flow for:
 - Microsoft 365
 - Internal applications
 - Client portal
 - Validate:
 - Successful SSO login
 - MFA enforcement
 - Token issuance and session handling
 - Simulate:
 - Invalid credentials
 - MFA failure scenarios
 - Unauthorized access attempts
-

4.6.6. Security Considerations

- Protect SAML assertions and OIDC tokens from interception
 - Use HTTPS for all communications
 - Implement token expiration and session timeouts
 - Monitor for token replay attacks
-

4.6.7. Risk Mitigation Measures

- Enforce strict Conditional Access policies
 - Enable logging and monitoring of authentication events
 - Limit token lifetime
 - Implement anomaly detection (impossible travel, unusual login patterns)
-

4.6.8. Recommended Usage at FinSecure

- Use SSO for:
 - Microsoft 365
 - Internal applications
 - Client-facing systems
 - Enforce MFA at IdP level for:
 - All users
 - All external access
-

4.6.9. Summary

SSO integration enables centralized authentication and consistent MFA enforcement across all enterprise systems at FinSecure. By leveraging SAML and OIDC protocols, the organization achieves secure, scalable, and user-friendly access management while reducing password fatigue and improving operational efficiency.

4.7 Active Directory Integration

4.7.1. Overview

Active Directory (AD) integration enables FinSecure Pvt. Ltd. to extend its existing on-premise identity infrastructure into a centralized authentication system that supports Multi-Factor Authentication (MFA).

Given FinSecure's hybrid environment, integration is achieved by synchronizing on-premise Active Directory with a cloud identity provider (Microsoft Entra ID), enabling unified identity management and MFA enforcement across both on-premise and cloud resources.

4.7.2. Architecture Components

- **On-Premise Directory:**
 - Windows Active Directory (Domain Controllers)
 - **Cloud Identity Provider:**
 - Microsoft Entra ID (Azure AD)
 - **Synchronization Tool:**
 - Azure AD Connect
 - **Users:**
 - Employees authenticated via AD credentials
-

4.7.3. Configuration Steps

4.7.3.1. Set Up Azure AD Connect

- Install Azure AD Connect on a dedicated server
 - Configure synchronization between:
 - On-prem AD
 - Microsoft Entra ID
 - Choose synchronization method:
 - Password Hash Synchronization (recommended)
 - Pass-through Authentication (optional)
-

4.7.3.2. Synchronize User Identities

- Sync:
 - User accounts
 - Groups
 - Password hashes
 - Ensure consistency:
 - Usernames (UPN format)
 - Email IDs aligned with Microsoft 365
-

4.7.3.3. Configure Authentication Method

- Select authentication approach:

Option 1: Password Hash Synchronization (Preferred)

- Users authenticate via Entra ID using synced credentials
- Supports cloud-based MFA easily

Option 2: Pass-through Authentication

- Authentication request sent to on-prem AD
- Requires on-prem agent availability

4.7.3.4. Enable MFA via Entra ID

- Apply MFA policies at cloud identity layer
 - Enforce MFA for:
 - All synced users
 - Privileged accounts
-

4.7.3.5. Configure Hybrid Identity Features

- Enable:
 - Single Sign-On (Seamless SSO)
 - Conditional Access policies
 - Ensure:
 - Domain-joined devices are recognized
 - User sessions are managed centrally
-

4.7.4. Authentication Flow

1. User logs in using AD credentials
2. Credentials are validated via Entra ID (or on-prem AD)
3. MFA challenge is triggered
4. Upon successful verification, access is granted

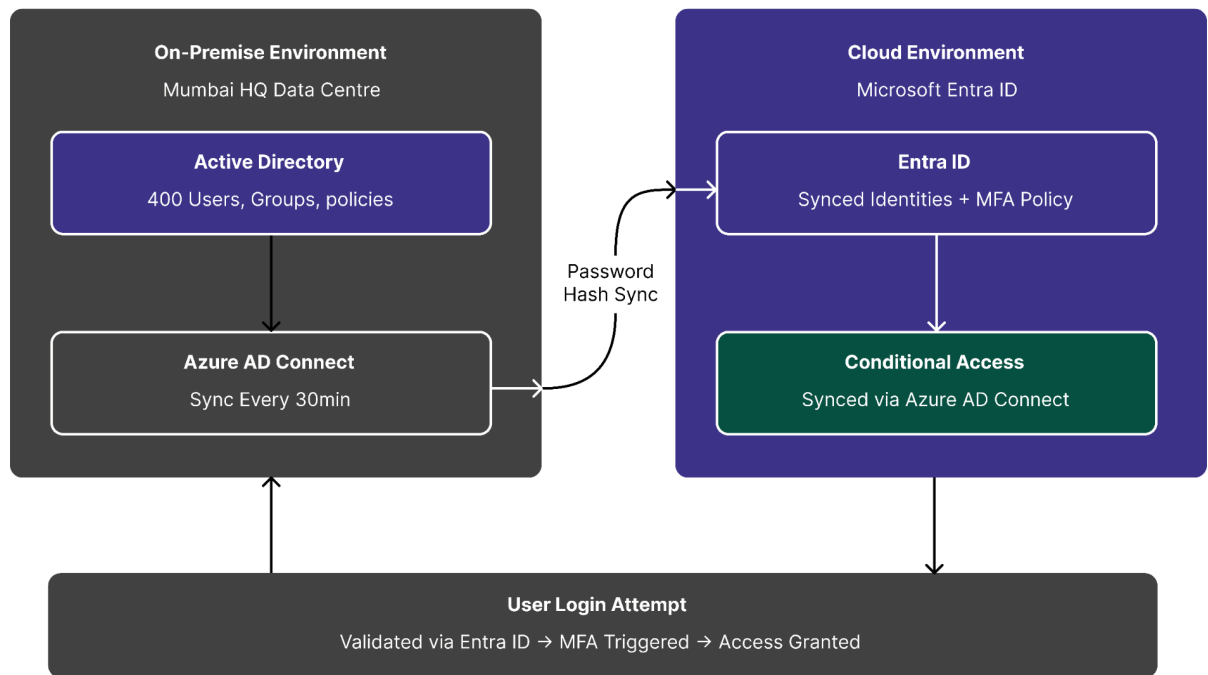


Figure 5: Active Directory sync and MFA enforcement flow

4.7.5. Testing & Validation

- Verify:
 - Successful synchronization of users
 - Login using AD credentials on cloud services
 - Test:
 - MFA enforcement for synced users
 - Password changes syncing correctly
 - Simulate:
 - Login failures
 - Account lockout scenarios
-

4.7.6. Security Considerations

- Protect Azure AD Connect server
 - Use secure communication (TLS)
 - Limit admin privileges on sync server
 - Monitor synchronization logs
-

4.7.7. Risk Mitigation Measures

- Restrict access to AD and sync servers
 - Enable logging and alerting for suspicious activity
 - Regularly audit user accounts and permissions
 - Apply least privilege access model
-

4.7.8. Recommended Usage at FinSecure

- Use AD as the **primary identity source**
 - Use Entra ID as the **authentication control layer**
 - Enforce MFA at cloud level for:
 - All users
 - All external access
-

4.7.9. Summary

Active Directory integration enables FinSecure to unify its identity infrastructure across on-premise and cloud environments. By leveraging Azure AD Connect and enforcing MFA through the cloud identity provider, the organization achieves centralized authentication, improved security, and seamless user experience.

4.8 VPN Integration (RADIUS-based MFA)

4.8.1. Overview

VPN integration with Multi-Factor Authentication (MFA) ensures that all remote access to FinSecure Pvt. Ltd.'s internal network is secured using strong authentication mechanisms.

Given that VPN access is one of the **highest-risk entry points**, MFA is enforced using a **RADIUS-based authentication flow**, where the VPN server delegates authentication to a centralized identity provider (Microsoft Entra ID).

This integration ensures that users must successfully complete MFA verification before gaining access to internal resources.

4.8.2. Architecture Components

- **VPN Server:**
 - Enterprise VPN solution (e.g., Cisco AnyConnect, Fortinet, OpenVPN)
 - **RADIUS Server / NPS:**
 - Network Policy Server (NPS) with MFA extension
 - **Identity Provider:**
 - Microsoft Entra ID (Azure AD)
 - **Users:**
 - Employees accessing internal systems remotely
-

4.8.3. Configuration Steps

4.8.3.1. Configure Network Policy Server (NPS)

- Install NPS role on Windows Server
 - Configure NPS as a RADIUS server
 - Add VPN server as a RADIUS client:
 - Define shared secret
 - Specify IP address
-

4.8.3.2. Install MFA Extension for NPS

- Install **Azure MFA NPS Extension**
 - Configure extension to:
 - Communicate with Microsoft Entra ID
 - Trigger MFA during authentication
-

4.8.3.3. Configure VPN Server

- Set authentication method to **RADIUS**
 - Configure:
 - RADIUS server IP (NPS server)
 - Shared secret
 - Enable secure protocols (e.g., TLS)
-

4.8.3.4. Define Access Policies

- Create policies in NPS:
 - Allow access for authorized users
 - Enforce MFA for all VPN logins
 - Apply restrictions:
 - Group-based access
 - Time-based or location-based policies (optional)
-

4.8.3.5. Integrate with MFA Workflow

- User initiates VPN connection
- Credentials are sent to NPS
- NPS forwards authentication request to Entra ID
- MFA challenge is triggered:
 - Authenticator app / push notification
- Access granted upon successful verification

4.8.4. Authentication Flow

1. User initiates VPN connection
2. Enters username and password
3. Request sent to NPS (RADIUS server)
4. NPS triggers MFA via Entra ID
5. User completes MFA challenge
6. VPN access is granted

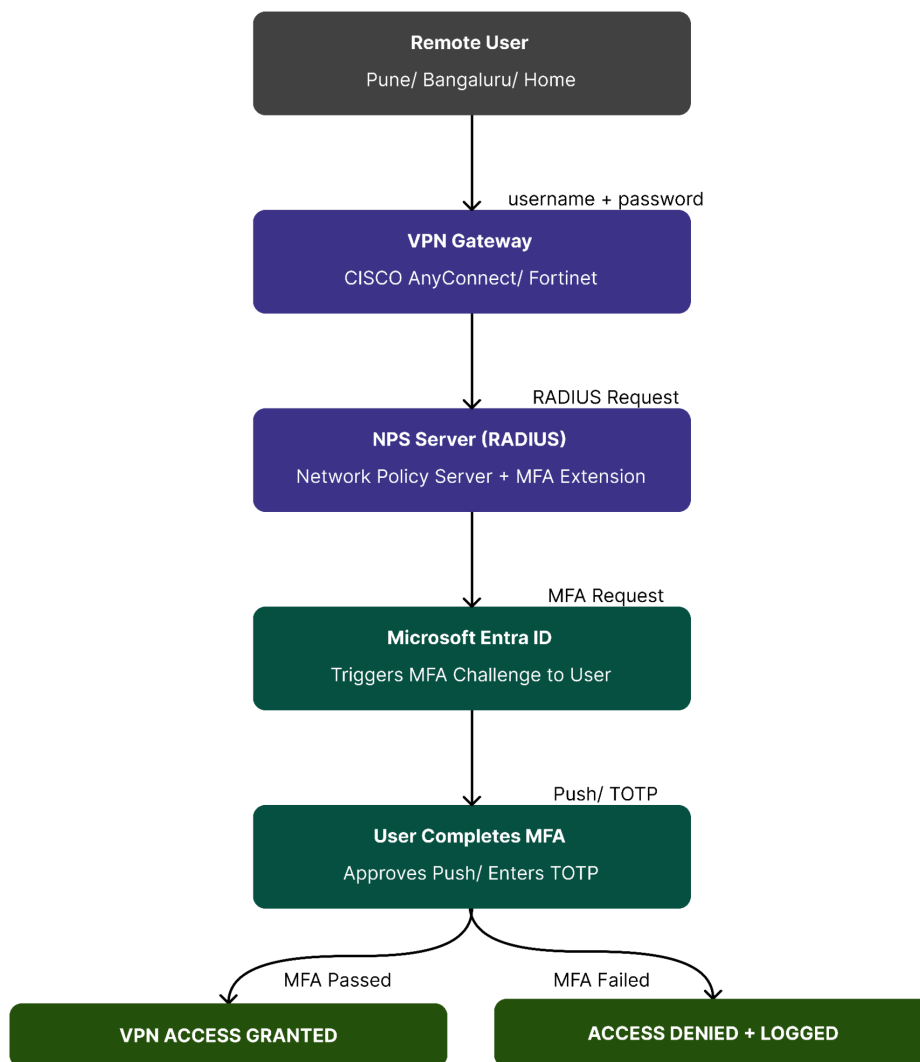


Figure 6: VPN RADIUS-based MFA authentication flow

4.8.5. Testing & Validation

- Test VPN login with:
 - Valid credentials + MFA ✓
 - Invalid credentials ✗
 - MFA rejection scenario ✗
 - Validate:
 - MFA prompt delivery
 - Successful connection after verification
 - Denial of access on failure
-

4.8.6. Security Considerations

- VPN is a high-risk external entry point
 - Ensure encrypted communication (TLS/IPSec)
 - Protect RADIUS shared secrets
 - Monitor VPN login attempts
-

4.8.7. Risk Mitigation Measures

- Enforce MFA for **all VPN users (no exceptions)**
 - Restrict access based on:
 - User groups
 - Device compliance
 - Enable logging and monitoring:
 - Failed login attempts
 - Suspicious access patterns
-

4.8.8. Recommended Usage at FinSecure

- Mandatory MFA for:
 - All remote users
 - Combine with:
 - Device compliance checks
 - Conditional access policies
 - Regularly audit:
 - VPN access logs
 - Authentication failures
-

4.8.9. Summary

VPN integration using RADIUS-based MFA ensures that all remote access to FinSecure's internal network is secured against unauthorized entry. By enforcing MFA at the network perimeter, the organization significantly reduces the risk of credential-based attacks and strengthens its overall security posture.

4.9 Internal Application Integration (HR & Loan Processing System)

4.9.1 Overview

FinSecure's internal applications — the HR system and loan processing system — present a unique integration challenge. Unlike Microsoft 365 or the client portal, these are on-premise legacy applications that were not designed with modern authentication protocols such as SAML or OIDC in mind.

Direct MFA integration is therefore not possible without an intermediary layer. Two approaches are available depending on the application's technical constraints.

4.9.2 Integration Options

Option 1 — Reverse Proxy with Entra ID Authentication (Recommended)

A reverse proxy is placed in front of the internal application. All user requests pass through the proxy, which authenticates the user against Entra ID (including MFA challenge) before forwarding the request to the application. The application itself requires no modification.

How it works:

1. User attempts to access the HR or loan processing application
2. Request is intercepted by the reverse proxy
3. Proxy redirects user to Entra ID for authentication
4. User completes MFA challenge
5. Entra ID issues a token to the proxy

6. Proxy forwards the authenticated request to the internal application
7. Application responds — user sees the app normally

Recommended tool: Microsoft Entra Application Proxy, which is built into Entra ID and requires no additional licensing beyond the existing Microsoft 365 subscription. It also enables these internal apps to be accessible securely over the internet without exposing them directly.

Option 2 — Network-Level Access Control (Compensating Control)

If the application cannot be placed behind a proxy, network-level controls can compensate:

- Restrict application access to VPN-connected users only
- Since VPN already enforces MFA (section 4.8), any user accessing the application has already passed MFA at the network entry point
- This does not provide application-level MFA but is an acceptable interim control while a full proxy solution is planned

This approach is less secure than Option 1 because MFA is enforced at the network perimeter rather than at the application itself. It should be treated as a temporary measure only.

4.9.3 Recommended Approach for FinSecure

Given the 8-person IT team and the need for a low-disruption rollout, the recommended approach is:

- Deploy Microsoft Entra Application Proxy for both the HR system and loan processing system during Phase 2 of the implementation plan
- Use network-level VPN restriction as an interim control during Phases 1 and the early part of Phase 2
- Retire the network-level restriction once Application Proxy is validated and stable

4.9.4 Configuration Steps — Entra Application Proxy

4.9.4.1 Install the Application Proxy Connector

- On a Windows Server inside the FinSecure network, download and install the Microsoft Entra Application Proxy Connector
- The connector establishes an outbound connection to Entra ID — no inbound firewall rules required
- Register the connector with the Entra ID tenant using IT admin credentials

4.9.4.2 Publish the Internal Application

- In the Entra ID admin portal, navigate to Enterprise Applications → New Application → On-premises application
- Configure:
 - Internal URL: the application's internal network address

- External URL: the public-facing URL users will access
- Pre-authentication: set to Microsoft Entra ID (enforces login before access)

4.9.4.3 Assign Users and Groups

- Assign the HR team group to the HR application
- Assign the Finance team group to the loan processing system
- Apply least privilege — no cross-access between departments

4.9.4.4 Enable MFA via Conditional Access

- Create a Conditional Access policy targeting the published application
- Require MFA for all access attempts
- This ensures MFA is enforced at the application level, not just the network level

4.9.5 Testing & Validation

Test	Expected Result
Access HR app via external URL	Redirected to Entra ID login + MFA
Access loan system via external URL	Redirected to Entra ID login + MFA
Access without VPN from unmanaged device	Conditional Access blocks or challenges
HR staff accessing loan system	Access denied — group assignment restricts access
Application Proxy connector goes offline	Access fails gracefully — users see error, not raw app

4.9.6 Security Considerations

- The Application Proxy Connector server must be treated as a critical infrastructure component — restrict local access and monitor it closely
- Internal URLs should never be exposed directly to the internet — only the external proxy URL should be reachable
- Session timeouts should be configured to match the organization's session management policy (section 5.1.7)

4.9.7 Summary

Microsoft Entra Application Proxy provides a clean, low-cost solution for extending MFA to FinSecure's legacy internal applications without requiring application code changes. Combined with group-based access control and Conditional Access policies, it ensures that HR and loan processing systems receive the same level of authentication protection as cloud services.

